

BVWA

Beego Vulnerable Web Application

OWASP Top 10:2025 | Versie 2.0 | Maart 2026

WAARSCHUWING: BVWA is uitsluitend bedoeld voor educatieve doeleinden. Gebruik het NOOIT in productie of op een publiek toegankelijke server. Draai het uitsluitend in een geïsoleerde, lokale testomgeving.

Inhoudsopgave

1. Projectoverzicht & Nieuw in v2.0
2. Installatie & Configuratie
3. Projectstructuur
4. OWASP Top 10:2025 Modules (A01-A10)
5. Login & Dashboard
6. Error Pages
7. Test Credentials
8. Technologieën
9. Disclaimer

1. Projectoverzicht & Nieuw in v2.0

BVWA (Beego Vulnerable Web Application) is een opzettelijk kwetsbare webapplicatie gebouwd met het Go Beego framework, gebaseerd op de OWASP Top 10:2025. Elke module toont een kwetsbare en een veilige implementatie met uitleg via een Info & CWEs knop.

GitHub: <https://github.com/B2TheEe/BVWA>

Nieuw in versie 2.0:

Feature	Beschrijving
Uniforme header	Alle modules hebben dezelfde BVWA-header met navigatie
Info & CWEs knop	Elke module heeft een modal met uitleg en alle CWEs
Kwetsbaar vs. Veilig uitleg	Per module uitleg waarom versie kwetsbaar/veilig is
Login systeem	Volledig login systeem met sessies en dashboard
Dashboard	Overzicht van alle 10 OWASP-modules na inloggen
Error pages	Aangepaste 400, 403, 404 en 500 errorpagina's
Inject simulatie	SQL injection zonder echte database via in-memory simulatie
Interactieve scenarios	A10 heeft klikbare test-scenario knoppen
Security log terminal	A09 toont live security logs in terminal-stijl

2. Installatie & Configuratie

Vereisten:

Tool	Versie	Website
Go	1.21+	golang.org
MySQL	5.7+	mysql.com
Beego	v2.x	beego.vip
bee CLI	v2.x	github.com/beego/bee
bcrypt	golang.org/x/crypto	pkg.go.dev

Installatiestappen:

1	Clone project <code>git clone https://github.com/B2TheEe/BVWA.git</code> <code>cd BVWA</code>
2	Dependencies <code>go mod tidy</code> <code>go get golang.org/x/crypto/bcrypt</code>
3	Bee CLI <code>go install github.com/beego/bee/v2@latest</code>
4	Database <code>mysql -u root -p</code> <code>CREATE DATABASE bvwa;</code>
5	Configureer app.conf Pas <code>db_user</code> , <code>db_pass</code> en <code>db_name</code> aan
6	Start app <code>bee run</code>
7	Open browser <code>http://127.0.0.1:8080</code>

conf/app.conf:

```
appname = bvwa  
httpport = 8080  
runmode = dev  
sessionon = true  
sessionname = bvwasession
```

```
db_user = root  
db_pass = jouwwachtwoord  
db_host = 127.0.0.1  
db_port = 3306  
db_name = bvwa
```

3. Projectstructuur

```
bvwa/  
|- conf/app.conf  
|- controllers/  
| |- access_control.go (A01)  
| |- security_misconfig.go (A02)  
| |- supply_chain.go (A03)  
| |- crypto.go (A04)  
| |- injection.go (A05)  
| |- insecure_design.go (A06)  
| |- auth.go (A07)  
| |- integrity.go (A08)  
| |- logging.go (A09)  
| |- exceptions.go (A10)  
| |- home.go (Homepage)  
| |- login.go (Login + Dashboard)  
|- routers/router.go  
|- views/  
| |- home/index.tpl  
| |- admin/dashboard.tpl (A01)  
| |- misconfig/index.tpl (A02)  
| |- supplychain/index.tpl (A03)  
| |- crypto/index.tpl (A04)  
| |- injection/sql.tpl (A05)  
| |- injection/xss.tpl (A05)  
| |- design/index.tpl (A06)  
| |- auth/login.tpl (A07)  
| |- integrity/index.tpl (A08)  
| |- logging/index.tpl (A09)  
| |- exceptions/index.tpl (A10)  
| |- login/index.tpl (Login)  
| |- login/dashboard.tpl (Dashboard)  
| |- errors/ (Error pages)  
| |- 400.tpl  
| |- 403.tpl  
| |- 404.tpl  
| |- 500.tpl  
|- main.go  
|- go.mod  
|- security.log  
|- README.md
```

4. OWASP Top 10:2025 Modules

A01 Broken Access Control

Toegangscontrole wordt niet afgedwongen. Gebruikers kunnen buiten hun bedoelde rechten handelen.

Kwetsbaar

Waarom kwetsbaar:

Geen sessie-/rolcontrole. Elke bezoeker heeft directe toegang via URL (Forced Browsing).

Veilig

Waarom veilig:

Server-side rolcontrole met `getSession()`.
Fail-closed: geen sessie = redirect naar login.

Route

Beschrijving

/admin/vulnerable

Kwetsbaar - geen auth

/admin/secure

Veilig - met sessiecontrole

A02 Security Misconfiguration

Ontbrekende of verkeerde security headers. 100% van applicaties getroffen.

Kwetsbaar

Waarom kwetsbaar:

Geen X-Content-Type-Options, X-Frame-Options, CSP of HSTS headers. Browser krijgt geen instructies.

Veilig

Waarom veilig:

Alle vier security headers worden per response ingesteld via `Header().Set()`. CSP met `unsafe-inline` voor demo-styling.

Route

Beschrijving

/misconfig/vulnerable

Kwetsbaar - geen headers

/misconfig/secure

Veilig - met headers

A03 Software Supply Chain Failures

Kwetsbaarheden via externe dependencies. Verouderde of onveilige packages.

Kwetsbaar

Waarom kwetsbaar:

MD5 gebruikt voor hashing: gekraakt algoritme, deterministische output, geen collision resistance.

Veilig

Waarom veilig:

SHA-256: modern, 256-bit output, collision-resistant. Controleer met `go mod verify` en `go list -m -u all`.

Route	Beschrijving
/supplychain/vulnerable	Kwetsbaar - MD5
/supplychain/secure	Veilig - SHA-256

A04 Cryptographic Failures

Zwakke of ontbrekende versleuteling. Vroeger: Sensitive Data Exposure.

Kwetsbaar

Waarom kwetsbaar:

MD5 voor wachtwoorden: geen salt, deterministisch, triviaal te brute-forcen (50+ miljard/sec op GPU).

Veilig

Waarom veilig:

bcrypt: ingebouwde salt, opzettelijk traag (~100ms), aanpasbare cost factor, timing-safe vergelijking.

Route	Beschrijving
/crypto/vulnerable	Kwetsbaar - MD5 hashing
/crypto/secure	Veilig - bcrypt hashing

A05 Injection (SQL & XSS)

Gebruikersinput als code uitgevoerd. SQL Injection en Cross-Site Scripting.

Kwetsbaar

Waarom kwetsbaar:

SQL: directe string concatenatie in query. XSS: str2html rendert raw HTML input van gebruiker.

Veilig

Waarom veilig:

SQL: geparametriseerde queries met ? placeholder. XSS: Beego escapet automatisch met {{.Variable}}.

Route	Beschrijving
/injection/sql/vulnerable	SQL - Kwetsbaar
/injection/sql/secure	SQL - Veilig
/injection/xss/vulnerable	XSS - Kwetsbaar
/injection/xss/secure	XSS - Veilig

A06 Insecure Design

Fundamentele ontwerpfouten in architectuur. Beveiliging moet ingebakken zijn, niet achteraf.

Kwetsbaar		Veilig	
Waarom kwetsbaar: Password reset zonder rate limiting: onbeperkte verzoeken mogelijk, user enumeration, geen verificatie.		Waarom veilig: Rate limiting (max 3 pogingen), token-gebaseerde reset, fail-closed, generieke responses.	
Route	Beschrijving		
/design/vulnerable	Kwetsbaar - geen rate limit		
/design/secure	Veilig - met rate limiting		

A07 Authentication Failures	
Zwakke authenticatie en sessiebeheer. Vroeger: Broken Authentication.	
Kwetsbaar	Veilig
Waarom kwetsbaar: Plaintext wachtwoord vergelijking, geen rate limiting, geen sessie-vernieuwing, info-lekkage.	Waarom veilig: bcrypt hashing, rate limiting per IP (max 5), DestroySession() voor login, generieke foutmeldingen.
Route	Beschrijving
/auth/vulnerable	Kwetsbaar - geen beveiliging
/auth/secure	Veilig - bcrypt + rate limit

A08 Software/Data Integrity Failures	
Geserialiseerde data zonder integriteitscontrole. Omvat insecure deserialization.	
Kwetsbaar	Veilig
Waarom kwetsbaar: Base64 sessiedata blind vertrouwd. Aanvaller kan role:admin en balance:999999 instellen.	Waarom veilig: HMAC-SHA256 handtekening op alle geserialiseerde data. Timing-safe vergelijking. Fail-closed.
Route	Beschrijving
/integrity/vulnerable	Kwetsbaar - geen handtekening
/integrity/secure	Veilig - HMAC-SHA256

A09

Security Logging & Alerting Failures

Beveiligingsgebeurtenissen niet gelogd. Aanvallen blijven onopgemerkt.

Kwetsbaar

Waarom kwetsbaar:

Geen logging van login-pogingen. Brute force aanvallen zijn volledig ondetecteerbaar.

Veilig

Waarom veilig:

Alle events gelogd naar security.log. CRITICAL alert na 3 mislukte pogingen. Live log terminal.

Route**Beschrijving**

/logging/vulnerable

Kwetsbaar - geen logging

/logging/secure

Veilig - volledige logging

A10

Mishandling of Exceptional Conditions

Onjuiste foutafhandeling. 24 CWEs. Fail-open gedrag en info-lekkage.

Kwetsbaar

Waarom kwetsbaar:

Fouten genegeerd met _. Negatief ID stilltjes gecorrigeerd (fail-open). Interne DB-details gelekt.

Veilig

Waarom veilig:

Alle fouten afgehandeld. Generieke meldingen. Fail-closed principe. Interne logging zonder lekkage.

Route**Beschrijving**

/exceptions/vulnerable

Kwetsbaar - fail-open

/exceptions/secure

Veilig - fail-closed

5. Login & Dashboard

BVWA heeft een volledig login-systeem met sessies. Na succesvol inloggen wordt de gebruiker doorgestuurd naar een dashboard met een overzicht van alle 10 OWASP-modules.

Route	Beschrijving
/login	Login pagina (GET = formulier, POST = verwerking)
/dashboard	Dashboard na inloggen - overzicht alle modules
/logout	Sessie vernietigen en redirect naar /

De /admin/secure route (A01) stuurt niet-geauthenticeerde gebruikers door naar /login. Na inloggen als admin wordt de sessie vernieuwd en de rol 'admin' ingesteld.

6. Error Pages

BVWA heeft aangepaste errorpagina's die consistent zijn met de rest van de applicatie. Ze zijn geregistreerd via `beego.ErrorHandler()` in `main.go`.

Code	Naam	Bestand	Kleur
400	Bad Request	<code>views/errors/400.tpl</code>	Blauw (#3498db)
403	Forbidden	<code>views/errors/403.tpl</code>	Paars (#8e44ad)
404	Not Found	<code>views/errors/404.tpl</code>	Rood (#e74c3c)
500	Internal Server Error	<code>views/errors/500.tpl</code>	Oranje (#e67e22)

De 500-errorpagina bevat een security-notitie die verwijst naar A10 (Mishandling of Exceptional Conditions). De 403-pagina verwijst naar A01 (Broken Access Control).

main.go registratie:

```
beego.ErrorHandler("404", page404)
beego.ErrorHandler("500", page500)
beego.ErrorHandler("403", page403)
beego.ErrorHandler("400", page400)
```

7. Test Credentials

Gebruikersnaam	Wachtwoord	Rol	Gebruik
admin	password123	Administrator	Login, A07, A09
user	user123	Gebruiker	Login (beperkte rechten)

Deze credentials zijn uitsluitend voor testdoeleinden. Gebruik ze nooit in een productieomgeving.

8. Technologieën

Technologie	Versie	Gebruik
Go	1.21+	Programmeertaal
Beego	v2.x	Web framework (MVC)
MySQL	5.7+	Database (ORM)
bcrypt	golang.org/x/crypto	Wachtwoord hashing
HMAC-SHA256	crypto/hmac	Data integriteit (A08)
SHA-256	crypto/sha256	Hashing (A03, A04)
bee CLI	v2.x	Development en hot-reload
reportlab	Python	PDF documentatie generatie

9. Disclaimer

BVWA is een educatief project. Het is opzettelijk kwetsbaar gebouwd om beveiligingsconcepten te demonstreren. Het gebruik van BVWA buiten een geïsoleerde testomgeving is uitdrukkelijk verboden. De auteurs aanvaarden geen enkele verantwoordelijkheid voor schade of misbruik voortvloeiend uit dit project. Gebruik altijd verantwoord en ethisch - uitsluitend op systemen waarvoor je toestemming hebt.